Experiment 1: Application Whitelisting Using AppLocker

Section 1: Aim

Aim: This experiment demonstrates how to implement application whitelisting on a Windows 11 Pro machine using Microsoft AppLocker. The goal is to create a policy that blocks executables from running in the Downloads folder, test it in Audit mode, enforce it, and verify the block through Event Viewer logs.

Section 2: What Is Application Whitelisting?

Application whitelisting is a security approach where **only explicitly approved applications are allowed to run**. Everything else is blocked by default.

This is the opposite of blacklisting, where known bad files are blocked. Whitelisting is stronger because unknown or new malicious files are automatically prevented from running, even if they have never been seen before.

AppLocker is Microsoft's built-in tool for implementing application whitelisting on Windows computers.

Section 3: Requirements for Experiment

To complete this experiment, the following requirements must be met:

Requirement	Details
Operating System	Windows 10/11 Pro, Enterprise, or Education
Administrator Access	Must be signed in as an administrator
Application Identity Service	Must be running (`AppIDSvc`)
Local Security Policy Editor	Accessible via `secpol.msc`
Test File	An `.exe` file placed in the Downloads folder

The Application Identity service is essential. Without it, AppLocker cannot evaluate rules or generate events.

Section 4: Steps Performed

The experiment followed these steps:

Step	Action
1	Started the Application Identity service
2	Created a test file (`test-app.exe`) in the Downloads folder
3	Opened AppLocker in `secpol.msc`
4	Created the three Default Rules (Windows, Program Files, Program Files x86)
5	Set enforcement to **Audit only** for safe testing
6	Created a Deny rule for `%OSDRIVE%\Users\DEEL\Downloads\*`
7	Ran `gpupdate /force` to apply the policy
8	Ran `test-app.exe` in Audit mode
9	Checked Event Viewer for Event ID 8004
10	Switched enforcement to **Enforce rules**
11	Ran `test-app.exe` again to confirm it was blocked
12	Checked Event Viewer for Event ID 8005
13	Tested the bypass by moving the file to the Desktop

Section 5: Key Concepts Learned

Default Rules Are Critical

AppLocker works on a deny-by-default principle. Without the Default Rules allowing Windows and Program Files, enforcing AppLocker would block the operating system itself and make the computer unusable.

Audit Mode Is a Safety Net

Audit mode logs what would happen without actually blocking anything. This allows testing rules before enforcement, preventing accidental lockouts.

Path Rules Have Limitations

Path rules block files based on their location. Moving the file to a different folder bypasses the block. This was demonstrated when `test-app.exe` ran successfully from the Desktop.

Event Viewer Provides Evidence

AppLocker logs every decision in Event Viewer under `Applications and Services Logs > Microsoft > Windows > AppLocker > EXE and DLL`. Event ID 8004 means "would have been blocked" in Audit mode. Event ID 8005 means "was blocked" in Enforce mode.

Section 6: Results

Test	Mode	Result	Event ID
Run test-app.exe from Downloads	Audit only	File ran; event logged	8004
Run test-app.exe from Downloads	Enforce rules	File blocked	8005
Run test-app.exe from Desktop	Enforce rules	File ran (bypass)	None

The experiment successfully demonstrated that AppLocker can block executables from a specific folder when enforced. The bypass test showed the limitation of Path-based rules.

Section 7: Conclusion

This experiment successfully demonstrated application whitelisting using AppLocker on Windows 11 Pro. The key findings are:

1. **AppLocker can block unauthorized executables** based on folder location.
2. **Audit mode is essential** for safe testing before enforcement.
3. **Default Rules must be created first** to prevent system lockout.
4. **Path rules can be bypassed** by moving files, so Publisher rules are recommended for stronger security.
5. **Event Viewer provides clear evidence** of what AppLocker allowed, audited, or blocked.

Application whitelisting is a powerful defense-in-depth control that limits the blast radius if an attacker gains access to a system. AppLocker makes this practical on Windows without requiring third-party tools.